

NARRATIVA EXPLICATIVA GQM + PRAGMATIC

El Porqué Profundo de Medir lo que Medimos y Como lo Medimos

CIA Triad Metrics Framework — España 2025

"Hay una diferencia epistemológica fundamental entre saber que tu organización es segura y saber cuánto de segura es tu organización. El primer conocimiento es fe. El segundo, ciencia. GQM + PRAGMATIC es el método que convierte la fe cibernética en ciencia aplicada."

INTRODUCCIÓN: EL PROBLEMA DE LA MEDICIÓN EN CIBERSEGURIDAD

La ciberseguridad tiene un problema que la distingue de casi cualquier otra disciplina técnica: sus mejores éxitos son invisibles. Cuando un ataque es prevenido, no hay noticia. Cuando un sistema permanece disponible el 99,99% del tiempo, nadie celebra el 0,01% de inactividad que se evitó. Cuando las credenciales de administrador permanecen seguras durante un año, no hay recompensa por ello.

Esta invisibilidad del éxito tiene consecuencias pragmáticas devastadoras para la gestión: sin métricas, la seguridad se convierte en un artículo de fe en el presupuesto, y los recursos fluyen hacia donde hay más ruido, no hacia donde hay más riesgo real. El CISO que no mide está condenado a justificar su presupuesto con el argumento circular de "no ha pasado nada gracias a lo que invertimos", que el CFO escéptico traduce como "podríamos no haber invertido nada y tampoco habría pasado nada".

GQM + PRAGMATIC rompe este círculo vicioso. No porque mágicamente haga visible lo invisible, sino porque construye una cadena de evidencia que va desde los objetivos estratégicos de la organización —y del Estado— hasta los datos técnicos más granulares, pasando por las preguntas precisas que necesitan respuesta.

PARTE I: POR QUÉ GQM — LA TRAZABILIDAD COMO VIRTUD CARDINAL

El Problema del "Indicador Huérfano"

Casi todas las organizaciones tienen métricas de ciberseguridad. El problema habitual no es la ausencia de datos; es la ausencia de propósito. Números producidos porque "siempre los hemos medido", dashboards llenos de gráficas de tendencias que nadie consulta, KPIs que no se vinculan a ninguna decisión concreta.

El indicador huérfano —aquel que existe sin un objetivo que lo justifique— es, en el mejor caso, ruido. En el peor, es una fuente de falsa tranquilidad: la sensación de que porque hay medición hay gestión.

La metodología GQM, desarrollada originalmente para ingeniería de software en el NASA Software Engineering Laboratory, propone una solución elegante: invertir el proceso. No "¿qué podemos medir?" sino "¿qué necesitamos saber para alcanzar nuestros objetivos?" La diferencia es la misma que existe entre un mapa que dibujamos para explorar y un mapa que dibujamos para llegar a un destino específico.

La Cadena de Trazabilidad: Del BOE al Byte

En el contexto del marco CIA Triad para España 2025, la cadena GQM se extiende sobre cuatro niveles:

Nivel 0 — Marco legal y regulatorio: El Real Decreto 311/2022 (ENS), la Directiva NIS2 (y su transposición LCGC en tramitación), el Reglamento DORA, el RGPD, el EU AI Act. Estos textos jurídicos establecen el horizonte normativo dentro del cual las organizaciones españolas deben operar.

Nivel 1 — Objetivos nacionales: Derivados de la normativa, expresados en términos de capacidades organizacionales. "Las organizaciones deben garantizar la confidencialidad de los datos de ciudadanos" (OBJ-NAC-01). No son métricas; son intenciones con respaldo jurídico.

Nivel 2 — Preguntas de medición: La traducción de los objetivos en preguntas específicas y respondibles. "¿Qué porcentaje de usuarios tiene MFA habilitado?" es una pregunta que puede ser respondida con datos. "¿La organización es segura?" no lo es.

Nivel 3 — Métricas técnicas: Las respuestas cuantitativas a las preguntas. Números con unidades, fuentes de datos identificadas, frecuencias de medición definidas y umbrales de actuación establecidos.

Este recorrido de cuatro niveles es el que convierte una auditoría de cumplimiento (¿tienes MFA?) en un sistema de gestión de seguridad (¿qué porcentaje de cuentas privilegiadas tiene MFA resistente al phishing y cuál es la tendencia mensual?).

La Taxonomía de Objetivos del Marco: Seis Objetivos, Tres Pilares, Un País

Los seis objetivos nacionales identificados en el marco integrativo no son construcciones académicas. Son la destilación de los objetivos explícitos de la Estrategia Nacional de Ciberseguridad 2022-2026, el CCN-STIC-006 (Política de Seguridad de la Información de la AGE) y los reglamentos europeos de aplicación directa.

OBJ-NAC-01 (confidencialidad de datos de ciudadanos) responde al RGPD y a los 122.223 incidentes gestionados por INCIBE en 2025, de los cuales más del 40% involucraron compromiso de datos personales.

OBJ-NAC-02 (integridad de sistemas críticos) responde al incremento del 30% en brechas por terceros (supply chain integrity) y a los ataques de sabotaje a infraestructuras críticas documentados por ENISA en 2025.

OBJ-NAC-03 (disponibilidad de servicios digitales) responde a DORA, a los 392 ataques de ransomware en España en 2025 y a la creciente dependencia digital de ciudadanos y empresas de servicios que no pueden interrumpirse.

OBJ-NAC-04 (autenticidad y no repudio) responde a eIDAS 2 y al crecimiento del 35% en uso de deepfakes en ataques documentados por IBM (2025).

OBJ-NAC-05 (gobernanza de IA) responde al EU AI Act y al dato de que el 63% de organizaciones carecen de política de IA generativa (IBM 2025).

OBJ-NAC-06 (criptografía post-cuántica) responde a los estándares NIST PQC publicados en agosto 2024 y al ataque HNDL que afecta al 67% de implementaciones criptográficas evaluadas en estudios de 2025.

PARTE II: POR QUÉ PRAGMATIC — LA CALIDAD DE LA MEDICIÓN COMO PREREQUISITO

El Problema del "Indicador Inútil"

Si el indicador huérfano es el error de los datos sin propósito, el indicador inútil es el error del propósito sin datos de calidad. Una métrica bien alineada con objetivos estratégicos pero que no puede obtenerse con precisión razonable, o que no genera acciones concretas, o que puede ser manipulada por quien es medido, es tan problemática como el indicador huérfano.

Los nueve criterios PRAGMATIC actúan como un filtro de calidad que evalúa si un indicador —aunque perfectamente alineado con GQM— merece un lugar en el cuadro de mando. Son la respuesta a la pregunta "¿pero esta métrica sirve de algo en la práctica?".

Diseción de los Nueve Criterios: Lo que Revelan de la Ciberseguridad Española

P — Predictivo: La Diferencia entre un Termómetro y un Barómetro

Un termómetro mide la temperatura presente. Un barómetro predice el tiempo futuro. En ciberseguridad, la mayoría de las métricas son termómetros: miden el estado actual de los controles. Los indicadores predictivos son los barómetros: permiten tomar decisiones preventivas antes de que el incidente ocurra.

De los 22 indicadores del marco, los que obtienen máxima puntuación en predictividad son TMPVC (I-02), MFA Coverage (C-01), Phishing Click Rate (AT-02) y Edge Patch Latency (A-06). No es casualidad: estos cuatro corresponden exactamente a los vectores de ataque más frecuentes según Verizon DBIR 2025. La predictividad real requiere conocer la epidemiología de los ataques.

El indicador C-04 (Cripto-Agilidad PQC) merece mención especial: es el único indicador del marco con horizonte temporal de décadas. Su predictividad es la más alta conceptualmente (predice el colapso de toda la criptografía actual ante ordenadores cuánticos suficientemente potentes), pero la más difícil de operacionalizar hoy. Es el indicador del barco que empieza a girar el timón con años de antelación.

R — Relevante: La Prueba de la Decisión

Un indicador es relevante si hay alguien que toma decisiones basándose en él. Esta prueba aparentemente simple elimina un porcentaje sorprendente de las métricas de ciberseguridad en uso.

En la evaluación del marco, todos los indicadores vinculados directamente a normativa con régimen sancionador (ENS, NIS2, DORA, RGPD) obtienen máxima relevancia. La razón es pragmática y algo cínica: la regulación con multas convierte cualquier métrica de cumplimiento en un indicador de riesgo financiero directo, y eso captura la atención del Consejo de Administración como ninguna argumentación técnica puede hacerlo.

La relevancia del indicador C-06 (Shadow AI) destaca por razones diferentes: no porque haya regulación sancionadora inmediata, sino porque el 63% de organizaciones sin política de IA generativa representan un riesgo emergente cuya dimensión financiera aún no está cuantificada pero cuya trayectoria es clara.

A — Accionable: El Test de la Reunión de Lunes

Para que una métrica sea accionable, debe superar lo que podríamos llamar el "test de la reunión de lunes": si el CISO la presenta al equipo operacional con el valor de la semana anterior, ¿sabe alguien qué hacer con él?

Indicadores como TMPVC, MFA Coverage, Uptime y MTTD superan este test con distinción: cada valor por debajo del umbral activa una acción específica, tiene un responsable asignado y un plazo razonable. El Índice de Madurez Zero Trust, en cambio, tiene accionabilidad más difusa: "estamos en nivel 1 y queremos estar en nivel 2" genera un proyecto de arquitectura de 18 meses, no una acción de la semana próxima.

Esta diferencia de granularidad temporal es importante: no todos los indicadores necesitan la misma inmediatez de acción. Los indicadores estratégicos de madurez alimentan hojas de ruta anuales; los indicadores operacionales alimentan standups diarios. Un buen sistema de métricas necesita ambos.

G — Genuino: La Honestidad Incómoda

El criterio Genuino es el más filosóficamente interesante del marco PRAGMATIC y el que produce las evaluaciones más incómodas. Obliga a preguntarse: "¿estamos midiendo el fenómeno real o una sombra conveniente del fenómeno real?"

El indicador C-06 (Shadow AI) ilustra perfectamente el problema: estamos midiendo el Shadow AI que el CASB puede detectar, no el Shadow AI total. Por definición, el Shadow —lo que se oculta— es más grande que lo que se detecta. Pero la alternativa (no medir porque la medición es incompleta) es peor que medir con imprecisión declarada.

El FIM Coverage (I-01) y la Firma Digital (I-04) son los más genuinos del conjunto porque miden exactamente lo que declaran medir: la presencia o ausencia de un control técnico verificable. La autenticidad de un certificado digital es un hecho binario y matemáticamente verificable; no hay ambigüedad posible en la interpretación.

La genuinidad de los modelos de madurez (especialmente ZT Maturity) es estructuralmente limitada porque dependen de autoevaluación. Un CISO que quiere quedar bien ante el Consejo tiene todos los incentivos para puntuar su organización generosamente. La solución —auditoría externa del nivel de madurez— existe, pero tiene un coste que la mayoría de organizaciones no está dispuesta a pagar. Este es uno de los dilemas no resueltos de la medición de seguridad.

M — Measurable: El Principio de Realismo

El criterio Measurable aplica el "principio de realismo": una métrica perfecta que requiere herramientas que la organización no tiene es, en la práctica, peor que una métrica imperfecta que se puede obtener hoy.

Los indicadores que obtienen puntuación más baja en Measurable son C-04 (PQC — requiere escáneres de criptografía especializados), C-06 (Shadow AI — requiere CASB), y C-03 (Cifrado en reposo — requiere CSPM/DSPM). En los tres casos, la medición requiere inversión previa en herramientas especializadas.

La recomendación práctica que emerge de este análisis es implementar los indicadores por niveles de madurez: empezar con los que se pueden medir con herramientas ya presentes (TMPVC, MFA, Uptime, MTDD) y progresar hacia los que requieren inversión adicional conforme la organización madura.

A2 — Preciso: Los Fantasmas del Inventario

La precisión de casi todos los indicadores del marco tiene un denominador común: depende de la calidad del inventario de activos. Una cobertura de MFA calculada sobre un directorio activo que tiene el 30% de las cuentas no actualizadas es un número que parece preciso y no lo es. Un TMPVC calculado sobre un scanner que no llega a todos los sistemas subestima la exposición real.

Esta observación tiene una implicación directa: el prerequisite oculto de todo el sistema de métricas es la calidad del inventario de activos. Un programa de métricas CIA que no empieza por la higiene del inventario construye sobre arena. El ENS Op.pl.1 y el NIS2 Art. 21(2)(b) exigen este inventario precisamente por esto.

T — Oportuno: El Tiempo Correcto para Cada Escala de Decisión

La oportunidad de una métrica depende de la escala temporal de la decisión que soporta. El uptime de servicios críticos necesita medición en tiempo real porque las decisiones de incidente son inmediatas. El nivel de madurez Zero Trust necesita medición semestral porque las decisiones arquitecturales tienen horizontes de meses.

La mayoría de los indicadores del marco cumplen bien este criterio porque se han diseñado con frecuencias diferenciadas según la naturaleza del indicador: tiempo real para operaciones (MTDD, uptime), semanal para vulnerabilidades activamente explotadas (TMPVC, edge patch), mensual para controles de cobertura (MFA, FIM), trimestral para cultura y formación, semestral para madurez estratégica.

I — Independiente: El Problema del Zorro Cuidando Gallinas

La independencia es el criterio que más tensión genera en la práctica. En un mundo ideal, todas las métricas de seguridad serían verificadas por terceros independientes. En el mundo real, las auditorías externas son caras, infrecuentes y a menudo superficiales.

Los indicadores que obtienen máxima independencia en el marco son los que tienen fuentes de verdad externas: los CVE son publicados por NVD/CISA (nadie en la organización puede cambiar la fecha de publicación de un CVE), los certificados digitales son emitidos y auditables por TSPs externos, los registros de notificación a INCIBE son verificables en el regulador.

Los indicadores de menor independencia son los que se autoestiman (madurez ZT, nivel de cultura), los que pueden ser manipulados temporalmente (estado de cuentas en IAM antes de auditoría) o los que requieren acceso especializado para verificación (integridad de logs).

La recomendación práctica: priorizar en el cuadro de mando ejecutivo los indicadores de alta independencia. Son los que el Consejo puede confiar sin que el equipo de ciberseguridad sea juez y parte simultáneamente.

C — Rentable: El ROI de Medir

El último criterio, y a menudo el más desatendido, pregunta si el coste de obtener la métrica es proporcional al valor que genera.

El análisis del marco revela una correlación positiva notable: los indicadores de mayor puntuación en Rentable son también los de mayor puntuación global (TMPVC, MFA, Uptime, MTDD). No es casualidad: los indicadores más útiles para la toma de decisiones tienden a basarse en datos que ya existen en la infraestructura de TI, y extraerlos tiene coste marginal bajo.

Los indicadores de menor rentabilidad percibida son los que requieren herramientas especializadas adicionales (PQC inventory, CASB para Shadow AI, DSPM para cifrado). Sin embargo, esta evaluación puede ser engañosa a largo plazo: el coste de no implementar la gestión de cripto-agilidad hoy puede ser el coste de migrar toda la infraestructura criptográfica en crisis en 2030-2035, lo que podría ser órdenes de magnitud más caro.

PARTE III: LAS TENSIONES DEL MARCO — HONESTIDAD INTELECTUAL

La Tensión GQM-PRAGMATIC: Objetivos Ambiciosos, Métricas Limitadas

El mayor reto del marco integrativo es la tensión entre la ambición de los objetivos (OBJ-NAC-06: preparar la transición cuántica) y la practicabilidad de las métricas (C-04 tiene puntuación de Precisión = 1 en PRAGMATIC).

La respuesta honesta es que esto no es un defecto del marco; es una característica de la realidad. Los objetivos nacionales deben ser ambiciosos. Las métricas deben ser honestas sobre sus limitaciones. La solución no es abandonar el objetivo porque la métrica es imprecisa; es declarar la imprecisión, usarla con las debidas reservas y mejorar la metodología de medición conforme la tecnología avanza.

La Tensión Predictivo-Genuino: Lo que Queremos Medir vs. Lo que Podemos Medir

El indicador AT-02 (Cultura de Seguridad / Phishing Click Rate) ilustra otra tensión fundamental: la phishing click rate mide la susceptibilidad al phishing en condiciones controladas, que es un proxy de la cultura de seguridad real. ¿Es un proxy válido? Parcialmente: correlaciona con comportamiento real pero no lo determina. Un empleado que nunca hace clic en simulacros puede aún así tomar decisiones inseguras en contextos no contemplados por los ejercicios.

La respuesta del marco es la misma que para la tensión anterior: declarar el proxy como proxy, no como la cosa misma. La phishing click rate es una aproximación útil de la cultura de seguridad, no una

medición directa. Usarla sabiéndolo es hacer ciencia aplicada. Usarla creyendo que mide directamente la cultura es hacer mala ciencia con aspecto técnico.

La Tensión Regulatoria-Técnica: El Umbral Normativo No es el Umbral Seguro

Una última tensión importante: los umbrales normativos (lo que la ley exige) y los umbrales técnicamente seguros (lo que la evidencia empírica recomienda) no siempre coinciden.

NIS2 exige "medidas adecuadas de gestión de riesgos" sin especificar umbrales cuantitativos para la mayoría de controles. ENS establece categorías (Básico/Medio/Alto) pero sin traducirlas en valores específicos de TMPVC o MTDD. Los umbrales propuestos en el marco (TMPVC $\leq$ 15 días para críticos, MTDD $\leq$ 30 días, MFA $\geq$ 99%) se derivan de la evidencia empírica de los informes de referencia 2025, no de prescripciones normativas.

Esta distinción importa: cumplir la norma es el mínimo legal exigible; alcanzar los umbrales técnicamente recomendados es el estándar de diligencia profesional. El marco GQM+PRAGMATIC sirve para ambas cosas, pero las confunde bajo responsabilidad del usuario.

PARTE IV: IMPLICACIONES PARA LA POLÍTICA CIBERNÉTICA ESPAÑOLA

El Caso del "Tier 1 con pies de barro"

España ocupa el Tier 1 del ITU Global Cybersecurity Index 2024 con una puntuación de 99,74/100 y es la segunda potencia mundial en centros de ciberseguridad. Al mismo tiempo, el 61% de sus empresas están en el nivel "Formative" (el más bajo) según el Cisco Cybersecurity Readiness Index 2025.

Esta paradoja —excelencia institucional, madurez empresarial rezagada— es precisamente la razón por la que un marco de métricas como GQM+PRAGMATIC es más urgente en España que en países con una distribución de madurez más homogénea.

El marco propuesto permite cuantificar esta brecha de forma rigurosa:

- Las grandes empresas y AAPP españolas pueden estar en IGM-CIA 3.5-4.0
- Las PYMEs (el 99,8% del tejido empresarial) pueden estar en IGM-CIA 1.5-2.5
- El promedio estadístico resulta en un número que describe a nadie perfectamente

Los 22 indicadores GQM+PRAGMATIC, aplicados de forma sistemática y con la sectorización adecuada, pueden proporcionar al CCN-CERT, INCIBE y al futuro regulador NIS2 español (MCE/DSN) un dashboard de madurez nacional que sea, por primera vez, trazable desde la normativa hasta el dato técnico y evaluado bajo criterios de calidad explícitos.

Hacia un Índice de Resiliencia Cibernética Nacional

La ambición máxima del marco GQM+PRAGMATIC para España es servir como base metodológica para un Índice de Resiliencia Cibernética Nacional (IRCEN) que permitiría:

1. Monitorizar la evolución de la madurez CIA en sectores esenciales de forma anual
2. Identificar los sectores y tamaños organizacionales con mayor brecha de madurez
3. Calibrar las intervenciones de política pública (programas de apoyo, incentivos fiscales, requisitos normativos diferenciados)
4. Contribuir con datos nacionales a los benchmarks europeos de ENISA (NIS Investments Report)
5. Comunicar a ciudadanos y empresas el estado real de la ciberseguridad nacional en términos comprensibles y verificables

Este Índice no sería una promesa; sería una cuenta de resultados de la resiliencia digital nacional, medida con el rigor que la gravedad de las amenazas exige.

Narrativa Explicativa GQM+PRAGMATIC CIA Triad v2025 · Referencias: Basili & Weiss (1984), GQM Standard (ISO/IEC 15939), Brothby & Hinson PRAGMATIC (2013), NIST SP 800-55 R1, ENISA NIS Investments 2025, IBM Cost of Data Breach 2025, Verizon DBIR 2025, Cisco CRI 2025, ITU GCI 2024, Estrategia Nacional de Ciberseguridad España 2022-2026